

Examen Architecture sécurisée

Version PDF générée à partir du document Word original.

École Centrale des Logiciels Libres et de Télécommunications

EC2LT

EC2LT

Rapport sur l'architecture sécurisée

Mouhamadou Falilou Sarr

Présenté par

•

Emile Royal Molowa

Mamadou Abou Diallo

OUATINOUE Jeyvet Espoir

Mouhamadou Falilou Sarr

Sokhna ami Dione

Mdadaqdcadeadaedeadaddedaegdkkkkkkkkk

Sous la supervision :

Mr. MBIAYE Samb

Table des matières

Introduction“@

1.1. Contexte et justification“@

1.1.2. Objectif du pratique"@

1.1.3. Porté du projet“@

Partie 1 : configuration fail2ban"@

Mise en œuvre"@

1. Installation de fail2ban“P

2. Configuration et test de fail2ban“P

Test 1“`

Test 2“p

Test 3"

Partie 2 : PortSentry sur linux"

1. Présentation de PortSentry“

1.1. Définition et fonctionnement“

1.1.2. Avantages et limitations“

Mise en œuvre“

2. Installation et Configuration“

2.1. Installation“

2.1.2. Configuration“ 0

TEST“ P

Partie 3: Proxi reverse avec linux“ p

Définition :“ p

Mise en œuvre“ p

1. Mise en place du proxy reverse :“ €

test“#

Partie 4: Load balancing“#

4.1. Présentation du Load Balancing :“#

4.1.2. Importance du Load Balancing :“#

Mise en œuvre“#

Test“#€

Partie 5: Pfsense“#•

5.1. Installation et Configuration“#•

5.1.2. Modification de paramètres utilisateur par défaut“#•

Mise en œuvre“#•

5.1.2.3. Configuration des interfaces réseau“3

5.2. Port Forwarding“3@

Mise en œuvre“3P

Test“3p

5.3. DMZ“3p

Mise en œuvre“3€

test“C

5.4. Portail Captif“C@

Mise en œuvre“CP

5.5. Squid et SquidGuard“S0

Mise en œuvre“S0

5.6. OpenVPN Accès“S0

5.6.1. présentation de OpenVPN“S0

Mise en œuvre“S@

Test“c

Partie 6 : VPN Accès avec WireGuard“cp

6.1. Présentation de WireGuard“cp

Mise en œuvre“cp

6.2. Installation et Configuration“cp

6.2.1. Installation de wireguard :“cp

Test“sP

Partie 7: . VPN Site à Site avec StrongSwan“s`

7.1. Présentation de StrongSwan“s`

Mise en œuvre“sp

7.2. Déploiement et Configuration“sp

Test“s•

Partie 8 : Couplage entre VPN Accès et DynDNS“f0

8.1. Présentation de DynDNS“f0

Mise en œuvre“f0

8.2. Intégration avec VPN Accès“f0

Conclusion et perspective“f@

Introduction

1.1. Contexte et justification

Dans un environnement informatique en constante évolution, la sécurisation des infrastructures réseau est devenue une priorité pour les organisations et entreprises, pour lutter contre les menaces, telles que les attaques par déni de service (DDoS), les intrusions non autorisées et l'espionnage industriel, nécessitent la mise en place d'architectures robustes et sécurisées.

La mise en place d'une architecture sécurisée est essentielle pour garantir la confidentialité, l'intégrité et la disponibilité des systèmes informatiques. Ce projet se justifie par les besoins suivants :

Sécurisation du réseau : L'intégration de pare-feu comme pfSense et la gestion des flux avec des outils tels que Fail2ban permettent de réduire les risques liés aux attaques externes et internes.

Contrôle des accès : L'utilisation de technologies comme les portails captifs et le port forwarding assure une gestion stricte des connexions et prévient les accès non autorisés.

Supervision et analyse : Des outils comme Nmap permettent de cartographier le réseau et d'identifier les vulnérabilités potentielles, tandis que Squid et SquidGuard assurent le filtrage et la régulation des accès Internet.

Optimisation du trafic : Le reverse proxy et le load balancing sont déployés pour garantir une répartition efficace de la charge et une disponibilité accrue des services.

Connexion sécurisée : Le recours à des solutions VPN comme OpenVPN, WireGuard et StrongSwan permet d'assurer une communication sécurisée entre les utilisateurs et les ressources de l'entreprise, en particulier pour les accès distants.

Gestion dynamique des noms de domaine : L'intégration de DynDNS facilite la gestion des accès à distance en attribuant des noms de domaine dynamiques aux ressources critiques.

1.1.2. Objectif du pratique

L'objectif de ce projet est de concevoir et de mettre en œuvre une architecture sécurisée intégrant des technologies avancées de contrôle, de déploiement et de supervision. Cette architecture repose sur l'utilisation de divers équipements et des solutions logicielles permettant une protection accrue contre les menaces potentielles tout en assurant une gestion efficace des accès et des ressources réseau.

1.1.3. Porté du projet

Ce projet vise à concevoir et à déployer une architecture sécurisée en intégrant des technologies avancées de contrôle, de déploiement et de supervision. La portée du projet couvre plusieurs aspects clés :

1. Conception de l'architecture :

Définition des exigences de sécurité et des besoins en infrastructure.

Sélection des équipements et solutions logicielles adaptés.

Élaboration d'un schéma d'architecture optimisé pour la sécurité et la performance.

2. Mise en œuvre des mécanismes de protection :

Implémentation de solutions de sécurité réseau (pare-feu, VPN, portSentry etc.).

Application des bonnes pratiques en matière d'intégrité des données dans le réseaux.

3. Automatisation et supervision :

Déploiement d'outils de prévention.

Intégration de solutions d'automatisation pour le déploiement et la gestion des applications déployée.

Mise en place de tableaux de bord pour assurer une surveillance proactive.

4. Tests et validation:

Vérification de la résilience face aux menaces potentielles (tests de pénétration, audits de sécurité).

Évaluation des performances et optimisation des configurations.

Documentation des résultats et recommandations pour l'amélioration continue.

Partie 1 : configuration fail2ban

Fail2ban est un outil de sécurité développé en langage python utilisable dans un système linux et Posix, très souvent accompagné de pare-feu soit de filtre de paquet, fail2ban renseigne les informations issues de réseau dans un fichier log les adresse IP potentiellement suspectes comme par exemple une adresse IP inconnue qui essaie de se d'accéder à plusieurs reprise à un service en local. Il bloque de façon automatique l'adresse pendant une période donnée définie par l'administration.

Mise en œuvre

Figure : architecture avec fail2ban

1. Installation de fail2ban

Avant de passer l'installation de l'outil fail2ban nous devons avoir comme prérequis :

une version récente de python .

comme pare-feu :

iptables ;

Shorewall ;

et TCP Wrappers.

Dans notre nous disposons comme pare-feu iptables. Passons à l'installation ci-dessous :

```
# apt update && apt upgrade
```

```
# apt-get install fail2ban
```

Figure: installation de fail2ban

2. Configuration et test de fail2ban

Une fois l'installation terminée on se déplace dans le répertoire /etc/fail2ban qui contient tous les fichiers de configurations essentiels à notre tâche administrative.

Il est de bonne pratique de sauvegarder les fichiers de configurations initiaux dans un nouveau fichier de même nom en modifiant juste l'extension en ".local" ou ".old". Dans la configuration de fail2ban, nous sommes amenés à mettre en place une prison destinée à contrôler toute les tentatives jugées malveillante au niveau des services définies dans cette prison se voit l'accès bloquer. La prison est définie dans le fichier de configuration jail.conf, il contient les exemples de configuration au niveau de fail2ban.

Ici l'on copie le contenu du fichier defaults-debian.conf dans un nouveau fichier jail.local que l'on va modifier.

```
# cp defaults-debian. Conf
```

```
# nano jail. Local
```

Figure : définition de la prison avec fail2ban

Description des paramètres de la prison :

enabled = (true/false) : elle permet d'activer la prise en charge du service défini par fail2ban

port = 22(ssh) : on définit le numéro de port du service

filter = sshd(daemon ssh) : nom du filtre provenant du fichier /etc/fail2ban/filter.d

logpath = /var/log/auth.log : on spécifie le chemin d'accès vers le fichier de logs qui doit être trié

maxretry = 1 : on renseigne le nombre maximal de tentatives échouées

Redémarrez fail2ban et vérifiez le statut du client (les services misent en prison) avec la commande :

```
# systemctl restart fail2ban
```

```
# fail2ban-client status
```

En exécutant la commande fail2ban-client status nous permet de passer en revue les services définis dans la prison avec les paramètres :

Number of jail : qui affiche le nombre de service,

Jail list : le nom des services renseignés.

Test 1

Durant la phase de test l'on utilise une machine attaquante qui va nous permettre d'effectuer dans un premier temps une demande d'authentification erronée par ssh au niveau de notre serveur.

Figure : présentation de l'adresse de la machine attaquante

Essayons plus de tentatives de connexion par ssh au niveau du serveur en faussant le mot de passe. Durant ces tentatives erronées de connexion, à la troisième tentative l'accès au service est suspendu comme le montre la figure ci-dessous :

Figure : test de connexion au serveur ssh

Affichage du journal :

L'affichage du fichier de journalisation des événements nous permet d'identifier les informations concernant le service avec une précision sur l'adresse IP de la machine suspecte et le numéro de port utilisé. La commande pour afficher le fichier de log est la suivante :

```
# cat /var/log/auth.log
```

Test 2

Procédant au changement des paramètres de la prison pour ce deuxième test. Cette fois on le nombre de période pendant laquelle les adresses suspectes doivent être recherchées par fail2ban et le nombre de temps pendant lequel les adresses doivent être bloquées avec les paramètres suivantes :

Findtime : période en secondes pendant laquelle les IP suspectes sont recherchées,

Bantime : période en secondes pendant laquelle une IP est bloquée.

Figure : modification des règles des prisons

Après la modification l'on redémarre le service de nouveau. Et recommençons les tentatives de connexion.

Figure : deuxième tentative de connexion

L'on affiche de manière instantanée le fichier du journal.

```
# tail -f /var/log/auth.log
```

Figure: journalisation des évènements

Dans la capture ci-dessus on peut distinguer les informations liées aux règles établies dans la prison. Nous remarquons ici qu'une première tentative de connexion est enregistrée avec la date et l'heure, et elle est par la suite bloquée avec le message (ban), vu que ça continue fail2ban bloque encore une deuxième fois (uban).

Avec la commande fail2ban-client status sshd nous présente le nombre de tentative échouée :

Total failed : 4,

Le fichier log d'authentification /var/log /auth.log que l'on a listé ci-dessus,

Le nombre total d'interdiction avec :

Total banned : 4,

Et la liste contenant l'adresse IP :

Banned ip list : 192.168.2.237.

Figure : affichage du statut client

Intégration de pare-feu :

Pour la prise en compte rapide du pare-feu par fail2ban l'on intègre le paramètre banaction dont on lui affecte le nom de notre pare-feu local qui est iptables.

Figure : prise en compte du pare-feu par fail2ban

Test 3

Quand on recommence à nouveau les tentatives, fail2ban bloque l'accès et il inscrit en même temps de façon automatique l'adresse de la machine suspecte dans les règles pare-feu de la machine serveur afin que celle-ci soit bloquée définitivement en rejetant toute communication venant de cette adresse IP vers le serveur.

Figure : application des règles de pare-feu

Partie 2 : PortSentry sur linux

1. Présentation de PortSentry

1.1. Définition et fonctionnement

PortSentry est un outil de surveillance et de détection d'intrusions fabriqué pour identifier et bloquer les tentatives de scans de ports sur un système d'information. Il fonctionne en écoutant les ports réseau pour détecter de potentielle activité suspecte, comme un balayage de ports ou une tentative d'accès non autorisée et les bloquer. Lorsqu'une menace est identifiée, PortSentry peut bloquer de façon automatique l'adresse IP de l'attaquant en mettant à jour les règles du pare-feu ou en modifiant les fichiers de contrôle d'accès au système.

1.1.2. Avantages et limitations

PortSentry est un logiciel de sécurité qui surveille et protège les ports réseau d'un système contre les tentatives d'intrusion. Cependant, il présente certaines limitations, notamment le risque de faux positifs qui peuvent entraîner le blocage d'adresses IP légitimes. De plus, il ne remplace pas un pare-feu ou un système de détection d'intrusion plus avancé, mais agit plutôt comme une couche de protection complémentaire.

les avantages et limites se présentent comme suit:

Les avantages d'utilisation :

Il détecte automatiquement les scans de ports suspects qui pourraient indiquer une tentative d'attaque ;

Il peut bloquer immédiatement les adresses IP malveillantes en ajoutant des règles au pare-feu ;

Sa configuration est relativement simple et ne nécessite pas de connaissances très avancées ;

Il génère des journaux détaillés des tentatives d'intrusion, utiles pour l'analyse ;

Il fonctionne en arrière-plan sans perturber les activités normales du réseau.

Les limites d'utilisation:

Il peut parfois bloquer des adresses IP légitimes s'il est mal configuré ;

Il ne protège pas contre tous les types d'attaques (comme les attaques DDoS ou les virus) ;

Les attaquants expérimentés peuvent contourner sa protection en utilisant des techniques avancées ;

Il nécessite une maintenance régulière pour ajuster les règles et éviter les faux positifs ;

Son efficacité dépend beaucoup de la qualité de sa configuration initiale ;

Il doit être combiné avec d'autres outils de sécurité pour une protection complète.

Mise en œuvre

Figure : simulation d'attaque par scanne de port

2. Installation et Configuration

2.1. Installation

Avant de passer à l'installation l'on doit avoir comme environnement :

Ubuntu 20.04,

Nmap installer sur une machine Ubuntu ou une machine kali-linux

Une fois les conditions en place on passe à l'installation.

```
# apt update && apt upgrade
```

```
# apt install portsentry
```

Durant l'installation portsentry nous informe que par défaut il n'applique aucun blocage. On clique sur "ok".

Figure: installation de portsentry

Pour vérifier qu'il n'applique pas réellement de blocage, on effectue un test de scanne de port en utilisant l'outil nmap sur la machine cible avec l'adresse IP (192.168.2.28).

Figure: test de scanne de la machine cible

On remarque que le scanne fonctionne au niveau

2.1.2. Configuration

Modifier le fichier de configuration de portsentry dans le répertoire /etc/default/portsentry.

```
# nano /etc/default/portsentry
```

Figure: modification du fichier /etc/default/portsentry

On active le blocage de scanne en ajoutant 1 dans les paramètres :

```
BLOCK_UDP="0"
```

```
BLOCK_TCP="0"
```

Figure: activation du blocage de scanne

Comme nous utilisons comme pare-feu iptables, l'on doit commenter la ligne suivante dans le fichier de configuration de portsentry.conf :

```
# KILL_ROUTE="/sbin/route add -host $TARGET$ reject"
```

Et décommenter la ligne suivante:

Figure: configuration de la règle iptables dans portsentry

```
TEST
```

Figure: teste de scanne sur la machine cible

Sur la capture ci-dessus l'on remarque les ports de nos services ne sont pas détectés par l'attaquant. Vérifions les actions du pare-feu durant cette attaque, on liste toutes les règles avec la commande:

```
# iptables -L
```

```
# iptables -line-number -L (pour voir la position de la règle dans la table)
```

Figure: affichage des règles iptables

Partie 3: Proxi reverse avec linux

Définition :

un serveur proxy, appelé également server mandataire, est un service situé dans le réseau entre le client et le serveur distant.

rôle d'un serveur proxy :

En tant qu'intermédiaire, il effectue au niveau du réseau les actions suivantes:

Filtrage : ce qui va permettre de bloquer certains sites ou certaines catégories de sites.

Cache : ce qui va permettre de mettre en cache les requêtes (exemple : page web) afin de les retourner plus rapidement aux postes de travail.

Compression : ce qui va permettre de réduire le poids des pages au moment de retourner le résultat aux clients.

Journalisation : toutes les requêtes reçues de la part des clients (postes de travail) seront stockées dans des journaux (logs).

Anonymat : puisque le se cache derrière le proxy, le serveur Web verra seulement le proxy.

Droits d'accès : puisque le proxy est un intermédiaire, il peut servir à positionner des droits d'accès pour filtrer les accès, au-delà du filtrage Web.

Mise en œuvre

Figure : architecture du serveur proxy

1. Mise en place du proxy reverse :

Prérequis :

Nginx

Ubuntu 20

Docker

Configuration des interfaces réseau des machines :

Commencez par fixer les adresses IP des machines présentent dans le réseau :

Serveur proxy : le serveur présente deux interfaces réseau, qu'il faut fixé les adresse.

eth0 : 10.10.10.1/24 (connecté au serveur)

eth1 : 20.20.20.1/24 (connecté au client)

machine cliente:

eth0 : 20.20.20.2/24

serveur ssh:

eth0: 10.10.10.2/24

Installation de nginx sur la machine proxy

Avant la mise en place du serveur proxy, il faut d'abord installer le serveur nginx.

```
# apt update && apt upgrade
```

```
# apt install nginx -y
```

Une fois l'installation terminée on active le service :

```
# service nginx restart
```

figure : redémarrage du serveur

Configuration de nginx comme serveur proxy:

La configuration de nginx comme serveur proxy s'effectue dans le fichier /etc/nginx/nginx.conf.

```
# sudo nano /etc/nginx/nginx.conf.
```

Et ajouter les lignes suivantes :

```
stream {  
    server {  
        listen 2222;  
        proxy_pass 10.10.10.2:22;  
    }  
}
```

Figure : modification /etc/nginx/nginx.conf

Description des paramètres :

Le bloc stream permet de gérer les connexions TCP.

listen 2222; indique que Nginx écoutera les connexions entrantes sur le port 2222.

proxy_pass 10.10.10.2:22; redirige ces connexions vers le serveur SSH cible à l'adresse 10.10.10.2 sur le port 22.

Redémarrez le serveur

```
# service nginx restart
```

Figure : test des configuration de nginx et redémarrage du serveur

Configuration du serveur ssh :

Au niveau du serveur ssh créer des compte utilisateur en l'attribuant des un nom et un mot de passe.

créez-en un avec les commandes suivantes :

```
# adduser groupe_6
```

Figure : création de compte utilisateur

Vous serez invité à définir un mot de passe et à remplir des informations facultatives.

Ensuite, on vérifier l'état du service SSH :

```
# service ssh status
```

Figure : vérification du statuts du serveur SSH

Si SSH n'est pas actif, démarre-le avec :

```
# service ssh start
```

Figure : démarrage du serveur ssh

test

Depuis le client (20.20.20.2), on va utiliser le proxy pour nous connecter au serveur :

```
# ssh groupe_6@20.20.20.1 -p 22
```

Figure : connexion par ssh au niveau du serveur

Connexion au server depuis le poste client-1 en utilisant l'adresse du serveur proxy est réussies.

Partie 4: Load balancing

4.1. Présentation du Load Balancing :

Le load balancing répartit les requêtes réseau ou applicatives sur plusieurs serveurs pour optimiser les ressources, garantir la disponibilité et prévenir les surcharges.

4.1.2. Importance du Load Balancing :

Optimiser l'utilisation des ressources disponibles.

Garantir une haute disponibilité des services.

Améliorer les performances en réduisant la latence.

Réduire les risques de surcharge et de panne d'un serveur unique.

Mise en œuvre

Figure : architecture avec un load balancer

Configuration des interfaces réseau :

Client : 20.20.20.2/24

Figure : configuration de l'interface cliente

Serveur Haproxy :

Passerelle cliente : 20.20.20.1/24

Passerelle serveurs : 10.10.10.1/24

Figure : configuration de l'interface du serveur proxy

Server-1 : 10.10.10.2/24

Figure : configuration du serveur-1

Server-2 : 10.10.10.3/24

Figure : configuration du serveur-2

Configuration du serveur haproxy :

Modifiez le fichier de configuration /etc/haproxy/haproxy.cfg.

```
# nano /etc/haproxy/haproxy.cfg
```

Ajoutez la configuration suivante :

```
global
```

```
log /dev/log local0
```

```
log /dev/log local1 notice
daemon
defaults
log    global
mode   http
option httplog
option dontlognull
timeout connect 5000ms
timeout client  50000ms
timeout server  50000ms
frontend http_front
bind 20.20.20.1:80
default_backend http_back
backend http_back
balance roundrobin
server server1 10.10.10.2:80 check
server server2 10.10.10.3:80 check
```

Figure: configuration du serveur haproxy

Après la configuration, redémarrez le serveur pour la prise en compte des configurations et voir en même temps son état après le redémarrage.

```
# service haproxy restart
```

```
#service haproxy status
```

Figure: redémarrage du serveur haproxy

Configuration des algorithmes de Load Balancing :

HAProxy supporte différents algorithmes de répartition. On peut tester les des différents algorithmes en modifiant le fichier `/etc/haproxy/haproxy.cfg` :

roundrobin (par défaut) : Répartit les requêtes de manière circulaire entre les serveurs.

leastconn : Envoie la requête au serveur ayant le moins de connexions actives.

source : Répartit en fonction de l'adresse IP source du client (utile pour conserver des sessions sur un serveur spécifique).

Figure : configuration des algorithmes

Bien qu'on ne peut pas appliquer plusieurs algorithmes simultanément à un même backend, mais c'est possible d'utiliser plusieurs en parallèle via des backends distincts.

Au niveau des serveur web, démarrez les services tels que :

Apache ;

Nginx.

Et s'ils ne sont pas encore installés, on utilise la commande suivante pour faire l'installation :

```
# apt install apache2
```

```
# apt install nginx
```

Démarrage du serveur apache au niveau des serveurs :

Serveur-1 :

```
# service apache2 restart
```

Figure : démarrage de apache sur le serveur-1

Serveur-2 :

```
# service apache 2 restart
```

Figure : démarrage de apache au niveau du serveur-2.

Configuration des pages web au niveau des serveurs web :

Sur le server-1

```
#nano /var/www/html/index.html
```

<Test de validation du server-1 avec le groupe_6>

Figure : création de page web

Sur le server-2

```
#nano /var/www/html/index.html
```

<Test de validation du server-2 avec le groupe_6>

Figure : création de page web du serveur-2

Ensuite on redémarre les servers :

```
#service apache2 restart
```

Test

Depuis le client, essayez à nouveau d'accéder via HAProxy :

```
#curl http://20.20.20.1
```

Figure : connexion aux serveur web à travers le serveur haproxy

Partie 5: Pfsense

5.1. Installation et Configuration

5.1.2. Modification de paramètres utilisateur par défaut

La modification des configuration par défaut de pfsense ne revient pas à modifier totalement toute les configuration, mais plutôt de modifier quelques informations selon nos besoins.

Nous allons laisser par défaut les informations comme :

Le nom d'hôte ;

Le nom de domaine du pare-feu ;

Dans le cadre de notre configuration nous avons pas besoin de définir un :

Un serveur DNS principal et secondaire ;

Un nom hôte serveur de temps

Etc.

Mise en œuvre

La configuration qui nous intéresse ici est de définir un nouveau mot de passe pour l'utilisateur admin.

Figure : modification de mot de passe administrateur.

5.1.2.3. Configuration des interfaces réseau

Par défaut nous disposons seulement de l'interface réseau wan qui permet au pfsense d'avoir accès à internet. Mais les machines qui sont dans le LAN n'ont accès à l'extérieur, pour cela nous allons nous assigner une interface réseau.

On clique sur interfaces -> assignements, on clique sur +add pour ajouter une deuxième interface réseau au notre pare-feu .

Figure : assignement des interfaces réseau.

Il nous faut configurer la nouvelle interface réseau en lui attribuant une adresse IP, car elle va nous servir de passerelle pour les machine LAN au moment où nous allons configurer le service DHCP pour le réseau local.

On sauvegarde et on applique cela.

Figure : attribution d'adresse IP à l'interface LAN.

Sur notre tableur de bord nous avons les informations complètes sur l'interface du réseau local.

Figure : affichage des informations liées à l'interface local.

Configuration des règles de trafics :

La configuration de règle de trafique permet au machine situé dans le LAN de pouvoir quitter leurs réseau et accéder au réseau externe (internet) en exposant les services qui sont u niveau du LAN disponible sur le réseau internet .

Figure : ajout d'une nouvelle règle

Renseignez les paramètres suivants :

Interface : wan

Adresse : ipv4

Protocol : any

Destination : wan adress

Redirect target : on indique l'adresse IP du LAN.

Et l'on applique la configuration, puis il reste à configurer la règle de trafic. Pour cela cliquez sur firewall -> rules.

Figure : ajout de règles

Cliquez sur modifier pour afficher le contenu de la règle de trafic.

Figure : modification des règles

Vérifiez si les règles sont correctement implémentées.

Figure : modification des règles de Traffic

Avec ces règles en place les trafics vont être fluides entre le réseau internet et le réseau local LAN.

5.2. Port Forwarding

Port forwarding ou réacheminement de port consiste à rediriger des paquets réseau sur un port donné d'un équipement réseau vers un autre sur un port donné. Ce principe se base sur le mécanisme de la translation d'adresse réseau pour passer d'un réseau à un autre.

Le principe du NAT consiste à utiliser une passerelle de connexion à internet, possédant au moins une interface réseau connectée sur le réseau interne et au moins une interface réseau connectée à Internet (possédant une adresse IP routable), pour connecter l'ensemble des machines du réseau.

Mise en œuvre

Figure : architecture de port forwarding

Configuration de la redirection de port

Figure : configuration de la redirection de port

Appliquez la configuration.

Figure : application de la configuration

La mise en place de la translation d'adresse a permis de manière simultanée la définition d'une règle de trafic automatiquement grâce au paramètre Filter rule association = 'add associated filter rule'.

Affichez la règle de trafic dans firewall -> rule.

Figure : affichage de la règle de trafic de redirection

Test

Dans le cadre de ce test, l'accès au serveur va se faire par l'intermédiaire de l'interface réseau du pare-feu (pfsense). Dans le navigateur renseigner l'adresse IP de la machine pare-feu plus le port défini durant la configuration.

Figure : la page web du serveur

5.3. DMZ

Une DMZ ou zone démilitarisée est un réseau périmétrique qui protège et ajoute une couche de sécurité supplémentaire au réseau local interne d'une entreprise contre le trafic non fiable dans le réseau.

L'objectif final d'un réseau de zone démilitarisée est de permettre à une organisation d'accéder à des réseaux non fiables, tels qu'Internet, tout en s'assurant que son réseau privé ou son LAN reste sécurisé. Les organisations stockent généralement des services et ressources externes, ainsi que des serveurs pour le système de noms de domaine (DNS), le protocole de transfert de fichiers (FTP), la messagerie, le proxy, le protocole VoIP (Voice over Internet Protocol) et les serveurs Web, dans la DMZ.

Mise en œuvre

Figure : présentation d'une architecture avec DMZ

Configuration du DMZ :

Avant de passer à la configuration des règles de trafic sur le DMZ, vérifiez l'adresse IP de la machine serveur présente au niveau du DMZ.

Figure : présentation de l'adresse du serveur web présente dans le DMZ

Mise en place des règles de trafic :

On se place dans Firewall -> Rules et on clique sur l'interface du DMZ puis +add.

Figure : ajout de règle

Renseignez les informations suivantes :

Interface : dmz

Adresse : ipv4

Protocole : TCP/UDP

Source : dmz

Destination : any

Figure : configuration de la règle de trafic au niveau du DMZ

Cette configuration permet à notre serveur web d'être visible depuis le DMZ.

Mise en place des règles entre Internet et DMZ :

Toujours au niveau de Firewall -> Rules -> DMZ on accepte toutes requêtes venant d'Internet.

Figure : configuration des flux entrants

Mise en place de la translation d'adresse avec la redirection de port :

Firewall -> NAT

Figure : configuration de la translation d'adresse

Figure : configuration du mappage d'adresse.

test

depuis la machine située dans le réseau internet, l'on accède au serveur web dans le DMZ directement en utilisant seulement l'adresse de l'interface du pare-feu présenté au réseau.

Figure : affichage de la page du serveur web

Interdiction de toute communication de la DMZ vers le réseau local LAN :

Dans firewall -> rules, et renseigner les informations suivant :

Action : block

Interface : dmz

Adresse : ipv4

Protocole :any

Source : dmz

Destination : lan adress

Figure : blocage de toute communication entrante du DMZ vers le LAN.

5.4. Portail Captif

Le portail captif est une technologie utilisée pour contrôler l'accès à un réseau Wi-Fi. On le retrouve souvent dans les lieux publics comme les hôtels, cafés, aéroports, universités et entreprises. Son but est de s'assurer que seuls les utilisateurs autorisés puissent se connecter à Internet.

Comment fonctionne un portail captif ?

Lorsqu'un utilisateur se connecte à un réseau Wi-Fi équipé d'un portail captif, il est automatiquement redirigé vers une page web spéciale. Cette page lui demande de s'authentifier avant d'accéder à Internet. L'authentification peut se faire de plusieurs façons :

Un mot de passe (fourni par l'établissement)

Un compte utilisateur (dans une université ou une entreprise)

Une acceptation des conditions d'utilisation

Un paiement (dans certains cas, comme les hôtels)

Les avantages du portail captif

Le portail captif permet de:

sécuriser le réseau en empêchant un accès libre et non contrôlé.

D'identifier les utilisateurs pour mieux gérer les connexions.

limiter l'usage d'Internet (temps de connexion, débit limité).

respecter la loi en enregistrant certaines informations sur les utilisateurs, notamment dans les lieux publics.

proposer de la publicité ou des annonces sur la page de connexion.

Mise en œuvre

Figure : architecture avec portail captif

Configuration du portail captif :

Le portail captif fait partie des services intégrés dans pfSense. Pour cela on clique sur services->portail captif.

Figure : accès au service du portail captif.

Une fois dans notre service nous avons trois actions principales à faire :

Nommer notre portail ;

Activer l'interface du portail ;

Définir l'interface réseau sur laquelle le portail doit être actif.

Notre portail actif est fonctionnel normalement, mais nous ne pouvons pas nous connecter parce qu'il nous faut créer des utilisateurs comme le montre la figure ci-dessous.

Création du portail

Figure : ajout de zone

On active le portail

Figure : configuration et activation de l'interface.

On utilise la base de données locale

Figure : sélection de base de données

On sauvegarde la configuration.

Figure : Affichage du portail

Création des comptes utilisateurs :

La création des comptes utilisateur se fait dans système -> Gestionnaire d'utilisateurs des comptes utilisateur.

Figure : gestionnaire des utilisateurs

Les paramètres du compte utilisateur

Figure : création des comptes utilisateurs

On modifie l'utilisateur pour lui donner des privilèges pour se connecter au portail

Figure : modification de l'utilisateur

Ajouter au compte utilisateur le droit de se connecter au portail captif.

Figure : Ajout de droit utilisateur

On se connecte avec le compte de notre utilisateur.

Configuration du modem :

Au niveau du mode renseigner les informations suivantes :

Nom du point d'accès

Fixer l'adresse IP du point d'accès

On met le mode de connexion du réseau LAN en mode static ip.

Figure : configuration du point d'accès

Test

Pour le test du fonctionnement du portail on utilise un client androïde avec le compte utilisateur.

Figure : connexion de l'utilisateur.

Figure : succès de connexion

Génération de coupons :

Cliquez sur coupons -> interfaces

Figure : configuration de l'interface

On active la génération du rouleaux à coupon

Figure : activation du coupon

Et on clique sur générer une nouvelle clé.

Figure : génération du coupon

Une fois sur la nouvelle page l'on active la création de rouleaux avec coupons et l'on modifie le coupon. On renseigne les informations par rapport à la :

Durée du ticket ;

Le nombre de compte ;

Le numéro du rouleau de coupons.

Figure : configuration du rouleau à coupons.

Figure : affichage des informations de notre coupon.

Il nous reste plus que de télécharger le coupons.

Figure : téléchargement du coupon.

Test

le coupons présente les 10 codes que nous avons générer. Et connectons nous avec les coupons générés.

Figure : connexion réussie

L'utilisateur s'est bien connecté au réseau. Mais après que les deux minutes défini sont passées, il est automatique déconnecter du réseau.

Figure : expiration du délai de la connexion.

5.5. Squid et SquidGuard

Un serveur Squid est un serveur mandataire (proxy) et un mandataire inverse conçu pour relayer les protocoles FTP, HTTP, Gopher et HTTPS. Contrairement aux serveurs proxy classiques, un serveur Squid gère toutes les requêtes en un seul processus d'entrée/sortie asynchrone, ce qui lui permet d'être plus efficace en termes de gestion des ressources, réduisant la latence et améliorant les performances du réseau. Squid met en cache les contenus des demandes fréquentes, ce qui optimise la bande passante et accélère l'accès aux pages web pour les clients.

Pour un contrôle plus avancé du trafic web, Squid peut être couplé avec SquidGuard, un filtre d'URL qui permet de restreindre l'accès à certains sites web en fonction de listes noires et blanches.

L'association de Squid et SquidGuard offre ainsi une solution complète pour optimiser l'utilisation de la bande passante tout en assurant un contrôle efficace et une meilleure sécurité du réseau.

Mise en œuvre

Figure : architecture avec squid squidGuard

Installation du squid et squidGuard et squid

Figure : installation de squidGuard

Figure : installation de squid

Vérifiant les paquets affichés

Figure : les paquets installés

Les trois paquets sont installés.

Génération de certificat :

Figure : Ajout du certificat

Le certificat contient les informations suivantes :

Description ;

Méthode d'utilisation du certificat ;

Le type de clé.

Figure : Création du certificat

Exportation du certificat :

Le certificat va permettre à squid d'appliquer le filtre de la communication défini dur la configuration.

Figure : exportation du certificat

Configuration du serveur squid proxy Server

Cliquez sur services -> squid proxy server.

il est important de supprimer le cache du disque pour ne pas avoir des problème durant la configuration.

Une fois le cache vidé, cochez les deux cases et préciser l'interface du proxy ci-dessous :

Activer la prise en charge du protocole HTTPS sur l'interface précisée et ajouter le certificat généré.

Activer la prise en charge d'adresse ipv4.

Figure : configuration du serveur squid

CONFIGURATION DU PROXY FILTRE

Cliquez sur services -> squidGuard.

Il est important de ne pas activer l'option " Check this option to enable SquidGuard" car il faut le préconfigurer avant de l'activer.

Cocher les deux cases suivantes pour activer les logs ci-dessous.

Figure : activation du log

Dans la section "Blacklist", cochez l'option "Check this option to enable blacklist" afin d'activer l'utilisation d'une blacklist, c'est-à-dire une liste noire.

Figure : Activation du black liste

On active le serveur squidGuard

Figure : activation du serveur squidGuard

Dans la section liste noire ou 'black liste' on ajoute dans la barre url de la liste des sites à bloquer afin qu'elle soit télécharger.

Figure : téléchargement la base de la liste

Afin d'exploiter la liste noire, nous devons créer des règles sous la forme d'ACL. Cliquez sur "Common ACL" afin de créer une règle de base et commune au sein de Squid, tandis que la section "Groups ACL" permet de créer des ACL ciblées, rendez-vous dans l'onglet default accès[all] et le mettre à deny.

Et l'on l'applique à tous les cibles.

Figure : Création de règle URL.

Afin d'éviter que les règles soient contourner la restriction en précisant l'adresse IP du serveur distant à la place du nom de domaine, cochez l'option "Do not allow IP-Addresses in URL".

Figure : activation de l'interdiction d'utilisation d' URL

5.6. OpenVPN Accès

5.6.1. présentation de OpenVPN

OpenVPN est un logiciel open-source permettant de créer des réseaux privés virtuels (VPN) sécurisés en utilisant des tunnels chiffrés. Il repose sur les protocoles SSL/TLS pour l'authentification et le chiffrement des données, offrant ainsi une solution flexible et robuste pour sécuriser les connexions à distance.

Principales caractéristiques

Sécurité élevée : Utilisation de certificats, d'algorithmes de chiffrement avancés (AES-256, ChaCha20) et d'authentification TLS.

Flexibilité : Fonctionne en mode routé (niveau IP) ou bridge (niveau Ethernet).

Compatibilité multiplateforme : Disponible sur Windows, Linux, MacOS, Android et iOS.

Facilité d'intégration : Peut traverser les pare-feu et fonctionne sur différents ports (TCP/UDP).

Gestion centralisée des clients : Supporte l'authentification basée sur des certificats ou des identifiants (login/mot de passe).

Cas d'utilisation

Accès distant sécurisé : Permet aux employés de se connecter aux ressources de l'entreprise depuis n'importe où.

Interconnexion de réseaux : Relie plusieurs sites distants via un tunnel chiffré.

Bypass des restrictions réseau : Permet d'accéder à Internet en toute sécurité dans les réseaux restreints.

Mise en œuvre

Figure : architecture réseau avec OpenVPN

Création de l'autorité de certification

Accédons au menu : System > Certificates et ajouter un certificat

Figure : ajout de certificat

Figure : création de certificat auto-signé.

Figure : présentation de certificat

Etape 2 : création de certificat server

Le certificat serveur doit être signé par notre autorité de certification que l'on crée en premier lieu et par la suite préciser le type de certificat l'on veut créer.

Cliquez sur Ajouter.

Figure : création de certificat serveur

Etape 3 : Création de compte utilisateur.

Pour la création de l'utilisateur, il faut indiquer un identifiant un mot de passe et cliquer sur Clic to create a user certificate pour qu'il vienne avec son certificat client.

Ajouter l'autorité de certification.

Figure : création de certificat client

Etape 4 : configuration du serveur Openvpn

Maintenant que les certificats sont opérationnelles et dont nous disposons d'un utilisateur, configurant le serveur openVPN.

Cliquez sur le menu 'VPN' puis 'openVpn'.

Renseigne les informations suivantes :

Mode serveur : Remote Access(SSL/TLS + User Auth)

Local Port : 1194

Peer Certificate Authority : notre autorité de certificat

Figure : configuration du serveur

Ensuite on va dans gestionnaire de paquetage on installe openVpnClient en tapant openvpn sur la barre de recherche des paquets et on l'installe.

Etape 5 : exportation du certificat utilisateur (client)

On va dans l'onglet VPN > OpenVPN

On exporte le certificat de l'utilisateur créer.

Figure : exportation de certificat

Etape 6 : Configuration des règles pour OpenVPN :

La règle consiste à l'autorisation de tous les paquet entrant par le WAN d'emprunter le tunnel VPN. Et également permettre au client d'utiliser les ressources serveur.

Cliquez sur firewall et :

l'interface: WAN ;

destination : WAN address ;

port destination : OpenVpn(1194)

Figure : mise en place de règles entrant

Etape 8 : Autorisation de flux vers les ressources

Ajoutez une nouvelle règles sur l'interface OpenVPN. Ce règle sert à autoriser l'accès en RDP à la machine cliente, d'utiliser le tunnel.

Figure : autorisation de flux aux ressources

Test

Etape finale: configuration du client

Sur le client on télécharge le OpenVPN pour Windows 10.

Figure : installation de openVPN sur le client

On extrait le paquet qui est compressé dans le répertoire C:\Program File\OpenVPN\config.

Figure : décompression et installation du paquet

Après installation OpenVPN est disponible, cliquez sur l'icône de l'ordinateur avec la clé et connecter.

Figure : connexion du client.

Figure : le client est bien connecté au serveur OpenVPN

Affichons les informations liées à la connexion du client.

Figure : informations de connexion du client

Connexion au niveau d'un client androïde

On télécharge dans Play Store ou App Store sur IOS le client openVPN.

Figure : installation du client openVPN

Récupérer le certificat client et l'ajouter au niveau de notre client.

Figure : ajout du certificat utilisateur.

On se connecte avec le login et mot de passe client.

Figure : connexion du compte utilisateur.

Partie 6 : VPN Accès avec WireGuard

6.1. Présentation de WireGuard

wireguard est un service VPN léger qui permet de traverser des réseaux non fiables garantissant l'intégrité des données. Le cryptage de la communication repose sur des clés publiques et privées pour que les pairs établissent un tunnel crypté.

Mise en œuvre

Figure : architecture d'un vpn d'accès

6.2. Installation et Configuration

6.2.1. Installation de wireguard :

Pour la mise en place du serveur VPN avec l'outil wireguard, il est important d'avoir le paquet git installé comme prérequis. Parce que l'on va devoir cloner le dépôt depuis la source.

Installation du paquet git :

```
# apt install git
```

Figure : installation de git

Avec le paquet git installé, permet au système d'utiliser la commande git clone pour récupérer l'outil wireguard depuis la source et faire son implantation directement au niveau du système.

```
# git clone https://github.com/pivpn/pivpn.git
```

```
# ./auto_install/install.sh
```

Figure : clonage du dépôt en local et installation de wireguard.

Durant l'installation l'on doit préciser :

L'interface réseau ;

Et l'utilisateur.

Figure : configuration de l'interface réseau et l'utilisateur.

Figure : choix de l'outil vpn

Figure : configuration du port

Figure : choix du serveur DNS

Cliquez sur DNS Entry pour avoir un serveur DNS publique directement dans le réseau.

Figure : choix d'un DNS publique

Figure : configuration d'un domaine

Après ces différentes phases, les clés du serveur VPN vont être générée de façon automatique.

Figure : fin de la phase d'installation

Configuration du serveur VPN :

Comme le serveur vpn est déployé au niveau d'une machine linux, qui par défaut ne permet un routage de paquet à travers son système, se voit changer dans le but de faciliter la mise en place du tunnel et la traversé des paquets.

Modifiez le fichier `/etc/sysctl.conf` pour faciliter le traversé de paquet dans la machine linux.

Figure : modification du comportement du noyau linux

On recharge le noyau pour que la configuration soit pris en compte.

Figure : application de la modification.

Personnalisation des paramètre du VPN :

La personnalisation des paramètres VPN permet de définir les paramètres suivant selon nos besoins comme :

Préciser l'adresse réseau et sous-réseau du serveur VPN

L'interface réseau utilisée

Port utilisé par Wirgurad

C'est dans le fichier `/etc/pivpn/wiregurad/setupVars.confv`

Figure : personnalisation des paramètres du serveur

Définition de l'interface wiregurad

Il est configuré dans le `/etc/wiregurad/wg0.conf`, c'est dans ce fichier que l'on configure l'interface réseau wg0 utilisée par wiregurad pour établir le tunnel VPN, dont on définit également les règles de pare-feu pour activer le transfert de paquets.

Figure : configuration de l'interface de wirgurad

Redémarrez le service.

Figure : redémarrage du service

Création de compte utilisateur :

Figure : création de compte utilisateur

Les informations liées au comptes clients sont stockées dans le fichier `configs/` suivit du nom de l'utilisateur avec l'extension `.conf`.

Figure : information sur le compte de mamis

Et pour que le client puisse accéder à internet on ajoute une règle MASQUERADE

```
# iptables -t nat -A POSTROUTING -o enp0s3 -j MASQUERADE
```

Test

Pour nous connecter avec un téléphone on remplit les informations du client ou on génère un code QR

On télécharge l'application Wireguard et on scan le code :

Figure : affichage du code QR de connexion

Utilisons comme client un téléphone Android ou IOS pour nous connecter au réseau VPN. Cependant il faut installé sur l'appareil le client wiregurad.

Figure : le compte Diallo et Molowa sont bien connecté au réseau VPN

Test client Windows

Téléchargement de wireguard par le client Windows (ghost) à travers le lien : <https://download.wireguard.com/windows-client/>.

Figure : téléchargement du client Windows

Après le téléchargement de Wireguard sur Windows le client doit recevoir son fichier de configuration. Pour cela nous allons utiliser WinSCP pour lui transférer son fichier de configuration.

Figure : importation du fichier de configuration utilisateur

Dans le client wireguard, importer le fichier de configuration de l'utilisateur.

Puis il choisit le fichier de configuration(ghost.conf)

Ensuite cliquer sur Activer.

Dès lors le VPN est activé et il obtient son adresse ip.

Lançons CMD pour vérifier avec la commande ipconfig.

Figure : affichage de l'adresse IP du client

Avec ping , testons la connectivité avec le serveur :

Figure : test de communication entre le client et le serveur

On voit que la connexion entre le serveur et le client à travers le tunnel virtuel s'établit avec succès.

Cliquons sur Journal dans Wireguard pour voir les messages échangés entre la machine Windows et le serveur.

Figure : vérification du journal

Partie 7: . VPN Site à Site avec StrongSwan

7.1. Présentation de StrongSwan

StrongSwan est un logiciel open-source qui permet de sécuriser les communications sur un réseau en utilisant le protocole VPN (Virtual Private Network). Il est principalement utilisé pour créer des connexions sécurisées entre différents appareils ou réseaux via Internet.

7.1.2. Pourquoi utiliser StrongSwan ?

Sécurité : Il protège les échanges de données grâce au chiffrement.

Confidentialité : Il empêche les personnes non autorisées d'espionner les communications.

Fiabilité : Il est reconnu pour sa stabilité et sa performance.

7.1.2.3. fonctionnement de StrongSwan

StrongSwan utilise le protocole IPsec (Internet Protocol Security), qui chiffre et authentifie les données envoyées entre deux sites. Il établit un tunnel sécurisé à travers lequel les informations transitent en toute sécurité.

Mise en œuvre

Figure : architecture de connexion

7.2. Déploiement et Configuration

Le but de mettre en place sur serveur VPN pour le transit des données d'un site A vers un site B est de garantir la sécurité de l'information lors de sa mise en réseau.

Afin de garantir l'intégrité des données entre nos deux sites, l'on convient de déployer un tunnel sécurisé entre les deux sites distants en utilisant comme outils StrongSwan.

Comme prérequis l'on utilise :

Gns3 pour l'insolation et l'intégration de machine dans la zone de test ;

une machine docker ubuntu 20.04.

on installe le paquet nano comme éditeur de text, iputils-ping, net-tools pour avoir accès aux commandes réseau.

7.2.1 Installation de strongSwan

Installation de strongswan au niveau des sites :

On installe strongswan au niveau des deux sites.

```
# apt install strongswan
```

7.2.2 configuration des sites

Configuration du site 1 :

```
# nano /etc/ipsec.conf
```

Figure : configuration du protocole ipsec sur le serveur du site 1

Pour l'établissement de connexion entre les deux site après la mise en place du tunnel sécurisé les deux sites doit devoir se partager un secrets fait office de clé mutuelle. Ce secret partager est configuré également au niveau du site 2 de manière identique.

La configuration du secret partage s'effectue dans le fichier ipsec.secrets.

```
# nano ipsec.secrets
```

Figure : configuration du secret partagé

Il est important de démarrer le service pour la prise en compte des configurations par le serveur.

```
# service strongswan start
```

```
# service strongswan status
```

Configuration du site 2 :

```
# nano /etc/ipsec.conf
```

Figure : configuration du protocole ipsec sur le serveur du site 2

On configure également le même secret partager au niveau du site 2.

```
# nano ipsec.secrets
```

Figure : configuration du secret partagé

Test

On vérifie l'établissement de la connexion entre les deux sites avec la commande :

```
# ipsec status
```

et faisant une capture wireshark pour voir la composition des messages envoyés durant la mise en place du tunnel.

Serveur du site 1 :

Serveur du site 2 :

L'on peut remarquer qu'au niveau des deux captures, qu'il y a bien mise en place de tunnel et que les données ont été bien encapsulées et chiffrées avec le protocole ESP SPIs.

Visualisons cela avec une capture wireshark.

Figure : visualisation de l'établissement de communication entre les sites.

Les deux sites communiquent à travers le tunnel mais les clients présents dans chaque site ne peuvent pas encore se contacter parce qu'ils disposent d'une adresse IP privée qui ne peut être routable.

De ce fait l'on doit mettre en place la notion de translation d'adresse afin de leur permettre de sortir du réseau local juste après le routage de leurs adresses IP en précisant l'interface de sortie.

Serveur du site 1 :

```
# iptables -t nat -A POSTROUTING -s 10.10.10.0/24 -o eth0 -j ACCEPT
```

Serveur du site 2 :

```
# iptables -t nat -A POSTROUTING -s 20.20.20.0/24 -o eth0 -j ACCEPT
```

Figure : application de la translation d'adresse après le routage

Après la mise en place de la translation des adresses après le routage de paquets, effectuant un test de communication entre les clients des deux sites.

Ping de client 1 vers client 2 :

Figure : test de communication entre les machines clientes

Visualisant la communication avec wireshark. Pour voir l' encapsulation des paquet on filtre avec la communication avec le protocole ESP.

Figure : capture de la communication entre les machine cliente.

Sur la capture wireshark on remarque que les adresses IP des machines clientes ne sont pas visible en claire. Les adresses disponible sur la captures sont celles des serveurs vpn, ce qui est tout à fait normal.

Conclusion et perspective

Ce projet a permis de concevoir et de déployer une architecture sécurisée intégrant des technologies avancées, de déploiement et de supervision. Grâce à une approche méthodique, les objectifs de la protection contre les menaces, d'optimisation de la gestion des accès et d'amélioration de la supervision ont été atteints. L'implémentation des solutions de sécurité réseau et des outils de monitoring a renforcé l'infrastructure face aux risques potentiels.

Cependant, la cybersécurité étant un domaine en constante évolution, des améliorations et évolutions futures peuvent être envisagées.